LLMマルチエージェントを用いたIoTファームウェア不正機能検出システムの設計と評価

伊東 実聖[1,a)]　上園 大智[1,b)]　原 悟史[1,2]　グエン チ ヴァン アン[1]　村上 洸介[1,3]　藤井 翔太[1]
佐々木 貴之[1,c)]　吉岡 克成[1,d)]

概要：IoT 機器のファームウェアに意図的に埋め込まれる不正機能は，正規の機能を装うため検出が難しく，既存手法は汎用性や網羅性の面で十分でない．LLM はこの課題に有望だが，単一の LLM に各ファイルを逐次入力する方式では，バイナリの解析や大規模なファームウェアへの対応に限界がある．本研究では，LLM を基盤とする複数の専門エージェントを協調させるマルチエージェントシステムを提案する．本システムは，ファームウェア内の全ファイルの列挙と対象製品の同定，逆コンパイル，コード・設定の監査，動作可能性評価，敵対的レビューといった役割を各エージェントに分業させ，文書に記載された機能との照合を通じて，文書に記載されておらず，意図的な不正機能を絞り込む．15 種類の不正機能を含むベンチマーク DarkWrt を用い，同一条件で 5 回の検出を独立に実行して評価した．その結果，適合率 100%，再現率 97.3% を達成し，報告項目に誤検知はなく，15 種類中 14 種類を全試行で安定して検出した．バイナリとして実装された機能に対しても，難読化・擬態・トリガー型実行といった検知回避をコードの意味と文脈から見抜いた．さらに，正解ラベルを示唆するメタデータやファイル名を書き換えても検出が維持され，追加した良性機能を誤って報告しないことから，検出が文字列の表層一致ではなく挙動に基づくことを示した．以上より，LLM エージェントの協調は，意味的・文脈的な理解を要する不正機能の検出に高い精度と再現性をもって有効に機能する．

キーワード：不正機能，AI エージェント，ベンチマーク

Design and Evaluation of a Multi-Agent System for Detecting Hidden Functionality in IoT Firmware

Misato Ito[1,a)]　Daichi Uezono[1,b)]　Satoshi HARA[1,2]　Nguyen Thi Van Anh[1]
Kosuke MURAKAMI[1,3]　Shota FUJII[1]　Takayuki Sasaki[1,c)]　Katsunari Yoshioka[1,d)]

Abstract: Hidden functionality intentionally embedded in the firmware of IoT devices is difficult to detect because it masquerades as legitimate functionality, and existing methods are insufficient in terms of generality and coverage. LLMs are promising for this task, but a naive approach that feeds each file sequentially to a single LLM is limited in its ability to analyze binaries and to scale to large firmware. In this work, we propose a multi-agent system that coordinates multiple specialized agents built on an LLM. The system divides the work among agents that handle roles such as enumeration of all files in the firmware and identification of the target product, decompilation, code and configuration auditing, viability assessment, and adversarial review, and it narrows down undocumented and intentional functionality by cross-checking against the documented functionality. We evaluated the system on DarkWrt, a benchmark containing 15 hidden functions, running the detection five times independently under identical conditions. The system achieved a precision of 100% and a recall of 97.3% with no false positives among the reported findings, detecting 14 of the 15 functions consistently across all trials. Even for functions implemented as binaries, it identified evasion techniques such as obfuscation, mimicry, and trigger-based execution from the meaning and context of the code. Moreover, detection was maintained even after rewriting metadata and filenames that could reveal the ground-truth labels, and newly added benign functions were not falsely reported as malicious, showing that detection is based on behavior rather than on superficial string matching. These results show that coordinating LLM-based agents is effective for detecting hidden functionality that requires semantic and contextual understanding, with high precision and reproducibility.

Keywords: Hidden functionality, AI agent, Benchmark

© 2026 Information Processing Society of Japan

This paper is work in progress and not peer-reviewed.

1. はじめに

ルータやネットワークカメラをはじめとするIoT機器のファームウェアには，悪意ある製造者やサプライチェーン上の攻撃者によって，バックドアや文書化されていない機能といった不正機能が意図的に埋め込まれることがある．本研究では不正機能を，機器やその利用者に害を及ぼしうる，公式な文書に記載されていない，意図的に組み込まれた機能と定義する．実際に，管理者権限を与える隠しアカウントや遠隔操作を許す隠しサービスなど，現実の製品において不正機能の混入が繰り返し報告されている [1]．これらは既知の脆弱性のように公開データベースと照合して発見できるものではなく，正規の機能を装って正規のファイルに紛れるため，その存在を見抜くことは難しい．

不正機能の検出については，これまでにさまざまな手法が研究されてきた．ファームウェアを展開して既知の脆弱性や危険な処理を横断的に調べる総合型の静的解析ツール [2], [3] が実務で広く用いられているほか，バイナリのシンボリック実行によって認証を回避する経路を発見する手法 [4] など，特定の観点に特化した検出手法 [5], [6] も提案されている．近年では，大規模言語モデル（LLM）のコード理解能力をセキュリティ解析へ応用する試みが広がり，ソースコードのリスク検知 [7] やファームウェア中の不審なコードの指摘 [8], [9] といった用途で成果が報告されている．

しかし，これらの手法には共通する課題が残されている．不正機能は，脆弱性と異なり公開データベースが存在せず，実例を集めたデータセットも悪用の懸念から公開されていないものが多い．そのため，既知のパターンを前提とする手法は汎用性が低く，またLLMを用いる手法についても，参照できる実例が乏しいことから，不正機能に関する十分な知識を備えているかは明らかでない．また，ファームウェアは製品ごとに構成が大きく異なり，数千から数万のファイルを含むことも珍しくないため，網羅的な解析には多大な労力を要する．LLMを用いる手法はこれらに有望であるが，単一のLLMに個々のファイルを逐次入力する素朴な方式には，テキスト形式のファイルしか読めずバイナリの挙動を解析できないこと，および入力長に上限があり複数のファイルにまたがって連携する不正機能を一貫して捉えにくいこと，という二つの限界がある．

[1] 横浜国立大学
Yokohama National University
[2] 富士ソフト株式会社
FUJI SOFT INCORPORATED
[3] 株式会社 KDDI 総合研究所
KDDI Research, Inc.
[a)] ito-misato-wh@ynu.jp
[b)] uezono-daichi-ct@ynu.jp
[c)] sasaki-takayuki-yv@ynu.ac.jp
[d)] yoshioka@ynu.ac.jp

本研究では，この課題に対し，LLMを基盤とする複数の専門エージェントを協調させるマルチエージェントシステムを提案する．ファームウェア内のファイルの列挙と製品同定，文書収集，逆コンパイル，コードと設定の監査，動作可能性評価，敵対的レビューといった役割を各エージェントに分業させ，製品の文書に記載された機能との照合を通じて，文書に記載がなく，かつ意図的に埋め込まれた機能を候補として絞り込む．意図性の判別にあたっては，起動処理への組み込みや複数ファイルの連携，難読化の有無といった，意図的な実装を示す手がかりに着目する．コードの意味と文脈を解釈することで，既知のパターンに合致しない新規の不正機能も，その挙動や文書との不一致を手がかりに検出できる．

評価には，OpenWrtをベースに15種類の不正機能が意図的に埋め込まれたベンチマークDarkWrtを用いた．DarkWrtは各不正機能の正解が既知であるため検出の成否を客観的に判定できる．基盤モデルには，役割に応じてOpus 4.8と，より軽量なSonnet 5を用い，再現性を確認するため同一条件で5回の検出を独立に実行した．その結果，適合率100%，再現率97.3%を達成し，15種類中14種類を全試行で安定して検出した．難読化・擬態・トリガー型実行といった検知回避もコードの意味と文脈から見抜き，バイナリとして実装された機能も逆コンパイルを通じて検出できた．さらに，正解を示唆するメタデータやファイル名を書き換えても検出が維持され，本来のOpenWrtには存在しない差分である良性機能を追加してもそれらを誤って報告しないことから，検出が文字列の表層的な一致ではなく挙動に基づくことを示した．

本研究の主な貢献は次のとおりである．

- バイナリを含む多様なファイルの解析と，ファームウェア中の多数のファイルからの候補の絞り込みを，複数の専門エージェントの分業と協調によって実現する不正機能検出システムを設計・実装した．
- ベンチマークDarkWrtを用いた5回の独立した試行により，本システムが高い適合率と再現率をもって，再現性のある検出を達成することを示した．
- 正解を示唆するメタデータやファイル名を改変しても検出が維持され，追加した良性機能を誤って報告しないことを確認し，検出が文字列の表層的な一致ではなく挙動に基づくことを示した．

2. 関連研究

2.1 不正機能の検知技術

不正機能やバックドアを検出する技術は，これまでに数多く提案されてきた．Firmalice[4] は，シンボリック実行によって認証を回避する経路を，Stringer[5] は，静的なデータ比較に着目してバックドアや未開示機能を，HumIDIFy[6] は，ファームウェア中の隠された機能をそれぞれ検出す

© 2026 Information Processing Society of Japan

る．また実務では，ファームウェアを展開して既知の脆弱性や認証情報，危険な処理を横断的に調べる総合型の解析ツールとして，EMBA[2] や FACT[3] が広く用いられている．これらは特定の観点や実装形式に着目するものが多く，コードの意味や文脈まで踏まえた網羅的な検出には限界がある．

2.2 LLM および AI エージェントを用いた解析

近年，大規模言語モデル（LLM）の高いコード理解能力をセキュリティ解析に応用する研究が急速に進んでおり，ソースコードのリスク検知 [7] などに用いられている．IoT 機器を対象としたものとしては，EAGLEYE[8] が，LLM を用いて隠された Web インターフェースを検出し，PANGOLIN[9] が，LLM による言語横断的なコード解析を通じてファームウェアの脆弱性を発見している．

さらに，複雑な検出課題を複数の小さな問題に分解できる点で，複数の LLM エージェントを協調させるマルチエージェントの手法も有効とされる．たとえば，GPTLENS[10] は検出を協調と敵対の二つのエージェントに分けることで誤検知を抑え，iAudit[11] は，判定を行うエージェントとそれを批判するエージェントを組み合わせている．これらは，ソースコードの脆弱性やスマートコントラクトを対象とするものであり，本研究のように，バイナリを含むファームウェア全体を対象として，文書に未開示かつ意図的な不正機能を複数の専門エージェントの協調によって検出する試みは，これまで十分に検討されていない．

我々はこれまで，単一の LLM を IoT ファームウェアの不正機能検知へ適用可能性を検証し [12]，実機上での動的解析を組み合わせた検知・検証の枠組みを提案 [13] や，実機を対象とした未開示機能の実態調査を行ってきた [14]．これらの研究により，LLM が IoT ファームウェアの不正機能検知に有効であること，および実機に未開示の機能が広く存在することが示された．一方，これらはいずれも単一の LLM を中心とするものであり，バイナリを含む大規模なファームウェアを複数の観点から体系的に解析する点に課題が残されていた．本研究は，これらを複数の専門エージェントの協調へと発展させるものである．

2.3 不正機能のデータセットとベンチマーク

検出手法を評価するには，正解が既知のデータセットやベンチマークが必要となるが，1 章で述べた理由で公開されていない．意図的に不正機能を埋め込んだベンチマークとしては，個々のプログラムにバックドアを埋め込んだ ROSARUM[15] がある．これに対し，本研究が評価に用いる DarkWrt[16], [17] は，不正機能を完全に動作するファームウェアの中に埋め込んだものであり，検出器は多数の正規のコンポーネントの中から不正機能を特定する必要がある．DarkWrt は 9 個の不正機能を含む初版を経て，複数の担当者が独立に 6 個の機能を追加することで，実装の多様性を高めた 15 機能の版へと拡張されている [17]．

3. 提案手法：不正機能検出マルチエージェントシステム

3.1 不正機能の定義

本研究では，不正機能を，機器やその利用者に害を及ぼしうる，製品の公式な文書に記載されておらず，意図的に組み込まれた機能と定義する．すなわち，不正機能は，悪性であること，文書に記載がないこと，意図的であることの三つの性質を持つ．これには，管理者権限を与える隠しアカウントや，外部からの遠隔操作を許す隠しサービスといったバックドアが含まれる．一方，既知の脆弱性のような，意図せず生じた欠陥は，本研究の対象とは区別される．

3.2 システム概要

提案システムは，全体を統括する単一のオーケストレータ（main-agent）と，特定の役割を担う複数のサブエージェントから構成される．オーケストレータ自身は解析を行わず，あらかじめ定義された手順に従って各サブエージェントを順次起動し，追加の解析が必要かどうかを判断して処理の繰り返しを制御する．解析は，準備・抽出・最終評価の三つのフェーズに分けて段階的に進められる（図 1）．

このように役割を分担した構成をとるのは，単一の LLM に各ファイルを逐次入力する方式がもつ限界に対応するためである．逆コンパイルや文書照合といった個別の処理を専門のエージェントに委ねることで，バイナリを含む多様なファイルを解析対象に含められる．また，一つのエージェントの判断を後段の別のエージェントが検証・統合する構成により，複数のファイルにまたがる関連を踏まえて判断できる．各フェーズを設けたねらいと，そこで得られる出力は，3.3 節以降で述べる．

本システムは，LLM を基盤とするエージェント実行環境である Claude Code 上に構築する．解析や判断の中核を担うエージェントには Opus 4.8 を，補助的な処理を担うエージェントには，より軽量な Sonnet 5 を用いる．

3.3 準備フェーズ

ねらい．本手法は文書に記載のない機能を不正機能の候補とするため，「どのようなファイルが存在するか」と「何が文書に記載された正規の機能か」を先に確定しておく必要がある．準備フェーズは，この二つをそれぞれ担う二つのエージェントで構成する．

処理．ファイル列挙・製品同定エージェント（recon）が，ファームウェアに含まれるすべてのファイルを列挙し，各ファイルの種別を記録するとともに，製品名や型番を手がかりに対象機器を同定する．次に文書収集エージェント（doc-collector）が，同定された製品名・型番をもとに Web

© 2026 Information Processing Society of Japan

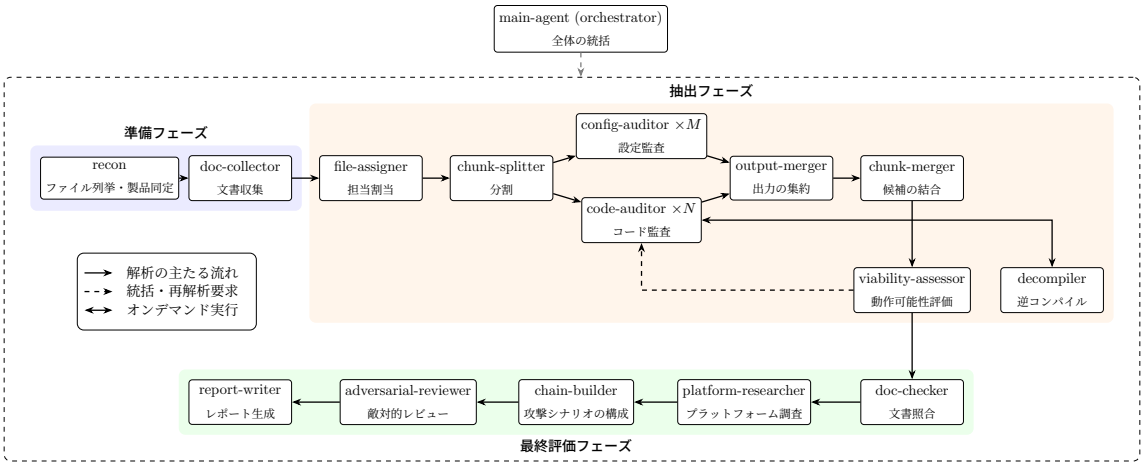


図 1　提案システムのワークフロー.

検索を行い，公式マニュアル等の文書を収集して，そこに記載された正規の機能の一覧を作成する.

出力. 本フェーズの出力は，(1) 解析対象となる全ファイルの一覧と，(2) 文書に記載された正規の機能の一覧である．(1) は，各ファイルのパス・種別・サイズに加え，解析対象とするか否かの区別（シンボリックリンクや空のファイル，フォントファイルは対象外とする）を含む.

3.4　抽出フェーズ

ねらい. ファームウェアは数千から数万のファイルを含むことも珍しくなく，これらを一度に解析することはできない．そこで抽出フェーズは，多数のファイルを内容に応じて振り分け，複数のエージェントで分担して並列に解析し，その結果を機能単位に統合する構成をとる.

処理. まずファイル割当エージェント（file-assigner）が，file コマンドによる種別やマジックバイトといったファイルの内容に基づいて，実行ファイルやスクリプトをコード監査エージェントに，設定ファイルや認証情報，パッケージのメタデータを設定監査エージェントに割り当てる．次に分割エージェント（chunk-splitter）が，割り当てられたファイルをディレクトリ単位で，一つのエージェントの担当が概ね 20 から 30 件程度になるように分割する．分割された対象は，設定監査エージェント（config-auditor）とコード監査エージェント（code-auditor）が並列に解析し，外部サーバへの情報送信，認証の回避や権限の昇格，隠しアカウントの設置といった不審な挙動や，文書に記載のない機能を候補として拾い上げ，各候補について正規の機能とも悪性とも解釈できる双方の見方を記録する．コード監査エージェントには準備フェーズで作成した正規の機能の一覧が与えられ，候補が文書に記載された機能かどうかの初期判定をあわせて行う．挙動の確認に深い解析が必要な ELF バイナリが見つかった場合には，逆コンパイルエージェント（decompiler）をオンデマンドで呼び出す．ファイル単位の候補は，統合エージェント（output-merger, chunk-merger）が機能単位に再結合し，動作可能性評価エージェント（viability-assessor）が，実際に動作しうるか，意図的に埋め込まれたものかを判断して，起動する仕組みを持たない残渣を除外する．判断の根拠が不十分な候補については，オーケストレータが監査エージェントを改めて起動して解析を補う.

出力. 本フェーズの出力は，各ファイルへの担当の割り当てを記録したファイル一覧，機能単位に統合された不正機能の候補の一覧，逆コンパイルされたバイナリのコード，および設定・状態の情報であり，これらが最終評価フェーズでの詳細な検証の対象となる.

3.5　最終評価フェーズ

ねらい. LLM は曖昧な機能を過剰に悪性と判断しやすく，抽出フェーズの候補をそのまま報告すると正規の機能を誤って不正機能とする恐れがある．そこで最終評価フェーズは，文書との照合，業界での一般性の調査，攻撃としての成立性の検討，そして敵対的な再検証という，互いに異なる観点の検証を段階的に重ねる構成とし，確度の高い不正機能に絞り込む.

処理. 文書照合エージェント（doc-checker）が，候補を文書と改めて詳細に照合し，文書に記載があれば除外し，記載がない，あるいは文書が不完全で判断できない候補は安全側に倒して残す．判断が困難な候補については，プラットフォーム調査エージェント（platform-researcher）が，ベンダの公式文書や既知の脆弱性データベースと照合し，業界で一般的に見られる正規の実装か否かを判断する．また連鎖構築エージェント（chain-builder）が，候補どうしを組み合わせて攻撃が成立するかを検討する．最後に敵対的レビューエージェント（adversarial-reviewer）が，各候補について，文書に記載されていないか，実際に動作するか，コードに根拠があるか，という三つの観点から最終的な確認を行う.

絞り込みの基準. 最終的に不正機能として報告するのは，

© 2026 Information Processing Society of Japan

悪性だと考えられ，文書に記載がなく，意図的に組み込まれ，かつ実際に動作する機能である．悪性か否かの判断は主観的になりやすいため，本システムでは，文書に記載があるか否かという客観的に確認できる基準も重視して絞り込む．正規の機能であっても文書に記載がなければいったん候補として拾い上げ，その挙動を精査したうえで正当と判断して除外することで，文書化されていない不正機能の見落としを防いでいる．

出力．これらの検証を通過した候補を，レポート生成エージェント（report-writer）が，検出の手がかりとなったファイル，文書に記載のない機能と判断した根拠，および意図的に埋め込まれたものと判断した根拠を検出レポートにまとめる．これがシステムの最終的な出力である．

4. 評価設定

4.1 評価用ベンチマーク DarkWrt

評価には，不正機能検出のためのベンチマークである DarkWrt を用いた．DarkWrt は，オープンソースのルータ用ファームウェアである OpenWrt をベースとし，現実の IoT 機器に見られる不正機能を模して，15 種類の不正機能を意図的に埋め込んだファームウェアイメージである．表 1 に，DarkWrt に含まれる 15 種類の不正機能の一覧を示す．各不正機能の設計や実装の詳細は先行研究 [16], [17] を参照されたい．本評価では，これら 15 種類の不正機能のそれぞれを正解とし，検出レポート（3.5 節）に記された各検出項目を，正解となる不正機能の実装や挙動と突き合わせて，対応する不正機能を検出できているかを判定した．

評価指標には，適合率と再現率を用いる．提案システムが不正機能として報告した項目のうち，正解の不正機能に対応するものを真陽性（TP），対応しないものを偽陽性（FP），正解の 15 種類の不正機能のうち，検出できなかったものを偽陰性（FN）とし，適合率 $\mathrm{TP}/(\mathrm{TP}+\mathrm{FP})$，再現率 $\mathrm{TP}/(\mathrm{TP}+\mathrm{FN})$ とする．

4.2 DarkWrt の良性機能

DarkWrt のバージョン 1.1 では OpenWrt に不正機能のみを加えて構築されているため，本来の OpenWrt からの逸脱がそのまま不正機能に一致する．提案システムが逸脱であることのみを手がかりに検出しているのであれば，正規の機能であっても逸脱していれば不正機能として報告してしまうはずである．この点を検証し，あわせて正規の機能を誤って報告しないことを確認するため，良性な機能が 6 個追加されている DarkWrt のバージョン 2 を用いた．内訳は，DarkWrt が独自に実装した 2 個（ネットワーク状態を監視する net-health，設定を自動でバックアップする confbak）と，OpenWrt で公式に配布されている 4 個（VPN の WireGuard，広告ブロックの adblock，帯域制御の SQM，トラフィック集計の nlbwmon）が実装されている．

本システムでは，不正機能を「文書に記載のない機能」と定義しているため，良性機能は文書に記載された機能として扱う必要がある．そこで，DarkWrt のバージョン 2 に同梱されている OpenWrt のユーザーガイドをもとに汎用的なマニュアルを作成し，追加した良性機能をそこに記載する条件と記載しない条件の二つを設け，文書への記載の有無が検出に与える影響を調べた．結果は 5.2.1 節で述べる．

4.3 実行条件

提案システムを Claude Code 上で動作させた．基盤モデルの使い分けは 3.2 節の通りである．検出結果の再現性を確認するため，同一のファームウェアと同一のプロンプトを与えて，検出を 5 回，互いに独立に実行した．なお，各不正機能の正解はエージェントには一切与えておらず，システムは製品の文書と実際のコード・設定のみをもとに，不正機能を自ら見つけ出す．各エージェントの役割と使用モデルは付録に示す．詳細なプロンプトの提供方針は付録 A.1 に述べる．

4.4 実機ファームウェアへの適用条件

提案手法が実世界のファームウェアにも適用できるかを確認するため，DarkWrt の評価に用いたものと同一のシステムを，市販の家庭用ルータ 4 機種のファームウェアに対して静的解析として適用した．本適用は，実機への適用可能性の確認を目的とするため，各機種に 1 回ずつとした．4 機種は 2 社の製品からなり，SoC・命令セットアーキテクチャ・ベース OS の異なる構成を含む．

5. 評価結果

5.1 5 回の試行による検出評価

5.1.1 検出結果

提案システムは，DarkWrt に含まれる 15 種類の不正機能に対して高い検出性能を示した．検出された不正機能の例を挙げる．隠しアカウント（F1）については，SSH デーモンと同じ名称を用いた利用者アカウントが作成されており，文書上は「パスワードなし」とされる箇所に実際にはパスワードハッシュが設定されていることを検出した．ポートノックによって起動する機能（F13, F15）については，特定の合図を一定回数受け取ると，システムを強制停止する，あるいはファイアウォールより先に起動して SSH を開放する処理を，本システムが逆コンパイルエージェントを呼び出して自律的に確認した．

5.1.2 再現性

5 回の試行のうち，15 種類中 14 種類（F1–F13, F15）は全 5 回の試行で安定して検出され，残る 1 種類（F14，SSH 起動機能（WebACL 改変））のみ 5 回中 3 回の検出にとどまり，2 回の試行で見逃しが生じた．この機能は二つの

© 2026 Information Processing Society of Japan

表 1 DarkWrt の不正機能一覧

ID	不正機能名	説明
F1	隠しアカウント	WebUI・SSH からログイン可能な隠しアカウントを設置
F2	認証機構改変	WebUI で特定のアカウント名が入力されると認証を回避
F3	権限昇格機能	root グループへの追加とパスワードなしの sudo 実行を許可
F4	パケット盗聴機能	通信をキャプチャしファイルに格納
F5	情報転送機能	一定時間ごとに機器内情報を指定サーバへ送信
F6	Telnet 起動機能	特定パターンのポートノックで Telnet を起動
F7	FW 設定変更機能	指定ファイルの有無に応じて特定ポートの FW 設定を変更
F8	キルスイッチ	起動直後にシャットダウンし機器を使用不能化
F9	痕跡消去機能	作成したファイル等を削除し痕跡を消去
F10	WebUI 認証情報漏洩機能	WebUI ログイン時に入力された認証情報を外部サーバへ送信
F11	SSH 起動機能（隠し Web ページ）	特定 URL へのアクセスで非標準ポートの SSH を起動
F12	C2 機能	外部サーバから定期的にコマンドを取得し実行
F13	キルスイッチ機能（ポートノック）	特定パターンのポートノックでシステムを強制停止
F14	SSH 起動機能（WebACL 改変）	隠し入力フィールドへの特定キーワード入力で SSH を起動
F15	SSH 起動機能（ポートノック）	特定パターンのポートノックで SSH 起動と FW 設定を変更

表 2 5 回の試行による検出結果

検出の安定性	不正機能	該当数
全 5 回で検出	F1–F13, F15	14
5 回中 3 回で検出	F14	1

ファイルにかかわっており，それぞれ異なる原因で見逃されていた（要因と改善策は 6.2 節で論じる）．

5.1.3 検出の決め手

各不正機能がどのような根拠で検出されたかを整理すると，次の 6 つの手がかりが繰り返し用いられていた．(1) 本来のファームウェアである OpenWrt に存在しないはずのファイルや，本来の内容からの逸脱，(2) 悪性の動作を明示する記述や作成者に固有の痕跡といったパッケージのメタデータ，(3) 起動時に実行されるよう登録された起動処理への統合，(4) 外部サーバのアドレスや固定のハッシュ値，起動の合図となる文字列といった固定値と，それらとの比較を経て破壊的な動作やサービスの起動へと至る流れの，逆コンパイルによる確認，(5) 秘匿設定・偽装応答・二重符号化・痕跡削除といった隠蔽の痕跡，(6) 別に正規の処理が存在するなど，正当な機能であるという弁明が成り立たないこと．

5.2 頑健性の検証

5.2.1 ラベル漏洩を除去した検証

DarkWrt のパッケージには，パッケージのメンテナ名や説明といったメタデータ，あるいは不正機能を示唆するようなファイル名が含まれており，これらが正解を露呈する手がかり（ラベル漏洩）となりうる．そこで，各不正機能の挙動を変えないまま，こうした手がかりとなる文字列のみを取り除いたファームウェアを作成し，検出が維持されるかどうかを検証した．

具体的には，約 2,170 件のパッケージ定義を走査して説明とメンテナ名を中立な内容に正規化し，不正機能を想起させるファイル名と関連する設定項目を中立な名称へ改めた．改名後のファームウェアでも，15 種類の不正機能がすべて動作することを確認している．

これらの操作を施したファームウェアに対しても，提案システムは不正機能を検出できた．良性機能をマニュアルに記載しない条件では 15 種類中 14 種類を，記載する条件では 15 種類すべてを検出した．ただし，両条件で検出数が異なったのは F14 の 1 種類のみであり，F14 はもともと試行によって検出が不安定な機能である（5.1.2 節）．したがってこの差は，良性機能の記載条件によるものではなく，F14 の検出の揺らぎによるものと考えられる．この結果は，本システムの検出が，文字列の表層的な一致ではなく，コードの挙動に基づいていることを示している．

5.2.2 良性機能に対する誤検知の検証

提案システムが正規の機能を不正機能と誤って報告しないかを検証した（良性機能の構成と条件は 4.2 節に示す）．マニュアルに記載しない条件では，6 個とも候補には挙がったものの，文書との照合ができないため挙動のみによって判断され，文書化されていない軽微な項目として記録されるにとどまった．たとえば監視機能は読み取りのみで外部通信を持たないことが確認された．マニュアルに記載する条件では，これらは文書と照合されて正規の機能と判断され，候補から除外された．これらの結果は，候補の絞り込みにおいて文書に記載があるか否かが実際に基準として働いていることを示している．また，追加した良性機能はいずれも本来の OpenWrt からの逸脱であるにもかかわらず，

© 2026 Information Processing Society of Japan

表 3 実機 4 機種への適用結果（初期候補と未開示機能の差は文書照合・動作可能性評価・敵対的レビューによる除外）

機種	リリース年	ファイル数	初期候補	文書化除外	未開示機能
A-1	2025	3,026	45	2	31
A-2	2025	4,062	67	8	12
B-1	2025	1,602	21	0	8
B-2	2025	1,135	40	0	27

不正機能として報告されなかった．本システムは，逸脱していることをそのまま不正の根拠とはせず，その挙動を精査したうえで判断していると考えられる．

5.3 実機ファームウェアへの適用結果

各機種について，本システムは候補を抽出し，文書照合・動作可能性評価・敵対的レビューを経て未開示機能を確定した．詳細は表 3 に示す．

文書に記載のある機能は正しく除外され，たとえばある機種では，公式文書に記載された機能の実装 8 件が候補から除外された．一方，機種固有の公式文書が存在しない機種では，文書照合による除外は 1 件も生じなかった．また，初期に不正と疑った挙動の一部は，後段の検証によって標準的な実装や動作しない残渣と判明して除外された．確定した未開示機能については，レポートに記された該当ファイルとコードを人手で確認し，記述された挙動が実装と一致すること，および文書に記載がないことを追認した．ただし，これは報告内容の裏付けを確認したものであり，各機能が不正機能であると断定するものではない．

確定した未開示機能のなかには，危険性が高いと考えられるものも含まれていた．たとえばある機種では，外部の第三者が管理しうるホストへ平文で定期的に通信し，その応答を検証せずにコマンドとして実行する，起動時から常駐する機能を，バイナリの逆コンパイルを通じて検出した．なお，検出した未開示機能のベンダへの報告については研究倫理節に述べる．

6. 考察

6.1 マルチエージェント構成の有効性

監査によって幅広く候補を洗い出したうえで，動作可能性の評価や敵対的レビューによる多段の検証を経て絞り込む構成が，誤検知の抑制と検出精度に寄与した．DarkWrt の 5 回の試行では，監査が各試行で 14〜19 件の候補を抽出し，これらを多段の検証にかけた結果，不活性な残渣やビルド由来の無害な項目，標準的なデフォルト機能などが除外・格下げされ，報告された項目に誤検知は生じなかった．

我々の先行研究 [13] では，Claude Code に解析の指示を与える方式で DarkWrt を評価している．逆コンパイル結果をあらかじめ人手で与えた場合の再現率は 49.3%，与えなかった場合は 77.3% であった．これに対し，本研究のマルチエージェント構成では，再現率 97.3%を達成しており，必要なバイナリのみをオンデマンドで逆コンパイルする分業構成が，検出漏れの抑制に寄与したと考えられる．

6.2 検出されなかった機能の要因

唯一，全試行での検出に至らなかった F14 は，二つのファイルにかかわり，それぞれ異なる原因で見逃されていた．一方は特定のキーワードで SSH を起動する処理を含むが，文字列検索によって解析対象から外れることがあった．これは処理時間短縮のため各エージェントの担当量を増やし，一度に扱う入力量が上限に達したことが一因である．他方は，あるサービスに通常は不要な実行権限を与えるわずか一行の変更であったが，本来のファームウェアと同一であると誤って判断され，解析されないことがあった．これらは，文字列検索を読み込み順序の決定のみに用いること，および改変が一つでも見つかった場合には解析を省略したファイルも改めて確認することで，改善できると考えられる．

6.3 実機ファームウェアへの適用と本手法の限界

本手法は，構成の異なる複数の実製品のファームウェアに適用でき，いずれの機種からも実在する未開示機能を検出できた．一方で，実機への適用は，DarkWrt に対する評価とは異なる困難を伴う．

第一に，本手法は主観的になりやすい悪性の判断を，文書に記載があるか否かという客観的な基準で補うため，製品の文書が整っていることを前提とする．実機の家庭用機器では公式文書が乏しい場合があり，そのときは絞り込みが難しくなる．第二に，実機では候補の一部が，工場出荷時の設定や診断といった，正当な用途とも悪用ともとれる保守機能であり，判断を候補ごとに個別に要する．これは，不正機能と正規機能が明確に分離した DarkWrt では生じにくいものであった．第三に，実機には各挙動の正解が存在しないため，適合率や再現率による定量的な評価もできない．第四に，本システムの検出には，本来のファームウェアである OpenWrt に存在しないファイルやそこからの逸脱が手がかりとして現れていた．DarkWrt は OpenWrt という明確なリファレンスを持つためこの手がかりが有効に働いたが，原型が公開されていないファームウェアに対して同程度の性能が得られるかは検証できていない．

また，誤検知の検証は追加した良性機能を対象としたものであり，あらゆる正規機能に対して誤検知をしないことを保証するものではない．以上から，DarkWrt に対する高い検出性能は，不正機能と正規機能の区別が容易で文書が整った理想的な設定におけるものであり，DarkWrt は現実の不正機能検知の難しさを十分に再現できていない可能性がある．

さらに，本研究の定義は意図的に組み込まれた機能を対象とするため，既知の脆弱性を認識しながら修正せずに放

© 2026 Information Processing Society of Japan

置するといった，不作為による危険は対象に含まれない．このような事例は現実の脅威として存在しうるが，放置が意図的かどうかをファームウェアの静的解析のみから判断することは難しく，対象範囲の拡張は今後の課題である．

7. 結論

本研究では，IoT 機器のファームウェアに意図的に埋め込まれた不正機能を検出するため，LLM を基盤とする複数の専門エージェントを協調させるマルチエージェントシステムを提案した．不正機能ベンチマーク DarkWrt を用いた評価では，5 回の試行を通じて適合率 100%，再現率 97.3%を達成し，15 種類中 14 種類を全試行で安定して検出した．また，メタデータの正規化やファイル名の改名を施しても検出が維持され，追加した良性機能を誤って報告しないことから，検出が文字列の表層的な一致ではなく挙動に基づくことを示した．

一方，本手法は文書への記載の有無を絞り込みの基準の一つとするため，文書が乏しい実機では絞り込みが難しく，保守機能との切り分けが課題となる．市販ルータ 4 機種への適用では，文書のない機種で文書照合による除外が働かず，DarkWrt が現実の不正機能検知の難しさを十分に再現できていない可能性を示した．今後は，文書が不完全な実機に対する検出の改善，より広範なバイナリへの対応，各構成要素の寄与の定量的な分析，および動的検証との組み合わせを通じて，実世界のファームウェアの不正機能検出へと本手法を発展させたい．

謝辞　本研究の一部はＮＥＤＯ（国立研究開発法人新エネルギー・産業技術総合開発機構）の委託事業「経済安全保障重要技術育成プログラム／先進的サイバー防御機能・分析能力強化」（JPNP24003）によるものである．本研究の一部は JSPS 科研費 26K21216 の助成を受けて行われた．

参考文献

[1] Andrei Costin, Jonas Zaddach, Aurélien Francillon, and Davide Balzarotti. A Large-Scale analysis of the security of embedded firmwares. In *23rd USENIX Security Symposium (USENIX Security 14)*, pp. 95–110, San Diego, CA, August 2014. USENIX Association.

[2] EMBA – the firmware security analyzer. `https://github.com/e-m-b-a/emba`. Accessed: 2026-07-31.

[3] FACT – the firmware analysis and comparison tool. `https://github.com/fkie-cad/FACT_core`. Accessed: 2026-07-31.

[4] Yan Shoshitaishvili, Ruoyu Wang, Christophe Hauser, Christopher Kruegel, and Giovanni Vigna. Firmalice – automatic detection of authentication bypass vulnerabilities in binary firmware. In *22nd Annual Network and Distributed System Security Symposium (NDSS)*, San Diego, CA, USA, 2015. The Internet Society.

[5] Sam L. Thomas, Tom Chothia, and Flavio D. Garcia. Stringer: Measuring the importance of static data comparisons to detect backdoors and undocumented functionality. In *Computer Security – ESORICS 2017*, Vol. 10493 of *Lecture Notes in Computer Science*, pp. 513–531. Springer, 2017.

[6] Sam L. Thomas, Flavio D. Garcia, and Tom Chothia. HumIDIFy: A tool for hidden functionality detection in firmware. In *Detection of Intrusions and Malware, and Vulnerability Assessment (DIMVA)*, Vol. 10327 of *Lecture Notes in Computer Science*, pp. 279–300. Springer, 2017.

[7] 鐘本楊，荒川玲佳，秋山満昭. LLM を用いたソースコードのリスク検知手法の検討. コンピュータセキュリティシンポジウム 2024 論文集, 2024.

[8] Hangtian Liu, Lei Zheng, Shuitao Gan, Chao Zhang, Zicong Gao, Hongqi Zhang, Yishun Zeng, Zhiyuan Jiang, and Jiahai Yang. EAGLEYE: Exposing hidden web interfaces in IoT devices via routing analysis. In *32nd Annual Network and Distributed System Security Symposium (NDSS)*, San Diego, CA, USA, 2025. The Internet Society.

[9] Zhipeng Jia, Xiaokang Yin, Shuitao Gan, Chao Zhang, Hangtian Liu, Jiangan Ji, Enzhou Song, Ruijie Cai, Jinglei Tan, and Shengli Liu. PANGOLIN: Fuzzing multilingual IoT firmware with LLM-driven code analysis. In *35th USENIX Security Symposium (USENIX Security)*. USENIX Association, 2026.

[10] Sihao Hu, Tiansheng Huang, Fatih Ilhan, Selim Furkan Tekin, and Ling Liu. Large language model-powered smart contract vulnerability detection: New perspectives. In *2023 5th IEEE International Conference on Trust, Privacy and Security in Intelligent Systems and Applications (TPS-ISA)*, 2023.

[11] Wei Ma, Daoyuan Wu, Yuqiang Sun, Tianwen Wang, Shangqing Liu, Jian Zhang, Yue Xue, and Yang Liu. Combining fine-tuning and LLM-based agents for intuitive smart contract auditing with justifications. In *Proceedings of the IEEE/ACM 47th International Conference on Software Engineering (ICSE)*, 2025.

[12] 伊東実聖，上園大智，九鬼琉，宮本岩麒，佐々木貴之，吉岡克成. IoT 機器の不正機能検知における LLM の有効性検証. コンピュータセキュリティシンポジウム 2025 論文集, 2025.

[13] 伊東実聖，上園大智，九鬼琉，宮本岩麒，原悟史，佐々木貴之，吉岡克成. LLM を用いた IoT ファームウェアの静的・動的解析に基づく不正機能の検知と実証. 電子情報通信学会技術研究報告, 2026.

[14] Misato Ito, Daichi Uezono, Ryu Kuki, Nguyen Thi Van Anh, Kosuke Murakami, Takayuki Sasaki, and Katsunari Yoshioka. Poster: An empirical investigation of backdoors and undocumented functionality through IoT real-device verification. 2026. `https://doi.org/10.5281/zenodo.21493500`.

[15] Dimitri Kokkonis, Michaël Marcozzi, Emilien Decoux, and Stefano Zacchiroli. ROSA: Finding backdoors with fuzzing. In *Proceedings of the IEEE/ACM 47th International Conference on Software Engineering (ICSE)*, pp. 2816–2828, 2025.

[16] 上園大智，櫛引淳之介，佐々木貴之，吉岡克成. DarkWrt: IoT 機器における不正機能のデータセット作成に向けた事例調査と分類. コンピュータセキュリティシンポジウム 2024 論文集, 2024.

[17] 上園大智，原悟史，佐々木貴之，吉岡克成. DarkWrt 1.1: 不正機能の埋め込みと検知トライアルを通じたデータセットの拡張と評価. セキュリティサマーサミット 2025, 2025.

[18] James C Davis, Sophie Chen, Huiyun Peng, Paschal C Amusuo, and Kelechi G Kalu. A guide to stakeholder analysis for cybersecurity researchers, 2025.

© 2026 Information Processing Society of Japan

研究倫理

本研究が扱う不正機能の検出技術は，防御と攻撃の双方に利用されうる．以下では，Menlo Report の原則に基づき，Stakeholder-Based Ethics Analysis の枠組み [18] に従い，本研究に関わるステークホルダーごとの便益とリスク，それらのリスクに対して講じた緩和策，および研究成果を公表する判断について検討する．

ステークホルダー．本研究のステークホルダーは，(1) 解析対象とした市販ルータ 4 機種のベンダ，(2) 当該製品の利用者，(3) 不正機能の検出に取り組む研究者・実務者である．また，本研究の成果を悪用しうる攻撃者を，これらのステークホルダーにリスクを生じさせる主体として考慮する．本研究は人を対象とする研究に該当せず，個人データも扱わない．評価に用いた DarkWrt は著者の一人が OpenWrt に不正機能を実装したものであり，第三者の製品を含まないため，(1)(2) へのリスクは主として 6.3 節の市販ルータへの適用に伴って生じる．

便益とリスク．(1) 解析対象とした市販ルータ 4 機種のベンダにとっては，自社製品や調達したコンポーネントに含まれる未開示機能を把握し，製品の安全性を改善する契機となる．一方，静的解析による未確認の結果が悪意ある機能として解釈された場合には，不当な評価や風評被害につながるリスクがある（**R1**）．また，クラウド LLM への解析データの送信により，製品に関する情報が意図せず二次利用されるリスクがある（**R2**）．

(2) 当該製品の利用者にとっては，危険な未開示機能の発見と修正が便益となる．一方，製品や不正機能を特定できる情報が公表された場合には，攻撃者による悪用を容易にし，利用者が被害を受けるリスクがある（**R3**）．また，解析において実際の機器やサービスに能動的な操作を行えば，利用者や第三者のシステムに影響を与えるリスクがある（**R4**）．さらに，検出した未開示機能をベンダに報告しないまま放置すれば，情報漏洩や機器の不正な制御といった危険が修正されずに残り，利用者が被害を受け続けるリスクがある（**R5**）．

(3) 研究者・実務者にとっては，正解が既知のベンチマークと検出手法を共有することで，不正機能検出技術の再現，検証，改善が可能になる．一方，本研究で示す検出手法や DarkWrt を攻撃者が転用し，第三者の製品から未開示機能を探索したり，検出を回避する不正機能の設計に利用したりすることで，ベンダや利用者に新たなリスクを生じさせる可能性がある（**R6**）．

リスクの緩和策．上記の各リスクに対し，以下の対策を講じた．

- **R1（ベンダへの不当な評価・風評被害）：**市販製品については，ベンダ名，製品名，型番など製品を特定しうる情報を公開しない．また，静的解析によって未開示機能の挙動が確認されたことのみをもって悪意の存在を断定せず，動作可能性や危険性を確認できていない具体的な検出結果も公開しない．
- **R2（解析データの二次利用）：**クラウド LLM への入力は，入力データがモデルの学習に利用されない設定で実行した．
- **R3（公開情報の悪用による利用者への被害）：**市販製品について，認証情報，固定値，通信先，具体的な起動条件など悪用に直結しうる情報を公開しない．
- **R4（解析行為による利用者・第三者への影響）：**市販製品については，ベンダの公式サイトから取得したファームウェアに対する静的解析のみを行い，第三者の機器やサービスに対する能動的な操作は行わなかった．DarkWrt の解析と動作確認は外部と隔離した仮想環境で行い，通信先も検証用サーバに限定した．
- **R5（未開示機能の放置）：**検出した未開示機能については，現在，動作確認を進めており，その結果を添えて該当ベンダへ報告する．静的解析のみでは，ある挙動が正規の保守機能であるか不正な機能であるかを外部から確定できないため，評価はベンダに委ねる．
- **R6（研究成果の攻撃への転用）：**不正機能の実装箇所や動作条件などを含む検出レポートの全文は公開しない．また，DarkWrt は動作する不正機能を含むため無制限には公開せず，研究・教育目的を確認したうえで申請に基づいて提供する．

公表の判断．本研究の公表は，不正機能検出手法の再現・検証・改善に資する一方，市販製品の解析結果や研究成果が悪用されるリスクがある（R1, R3, R6）．そこで，製品を特定しうる情報や悪用に直結する情報を公開せず，DarkWrt の提供も制限した．また，本研究で用いた LLM や同種の解析技術は一般に利用可能であり，手法の公表による攻撃能力の増分は限定的と考えられる．以上より，残存リスクよりも防御側への便益が上回ると判断し，本研究成果を公表することとした．

付　　録

A.1 Open Science

本研究の再現性と透明性のため，主張の評価に必要な成果物の所在と公開可否を述べる．各エージェントの詳細なプロンプトは，不正機能の探索に直接利用できる情報を含むため公開しない．ただし，再現性の確保のため，研究目的での利用については，申請に応じて利用目的を確認した上で提供する．DarkWrt に対する検出結果の内訳は 5.1.2 節の表 2 に示す．

DarkWrt のファームウェアイメージおよび不正機能のソース，ならびにラベル漏洩除去のスクリプト，追加した良性機能のソース，評価用マニュアルは，研究・教

© 2026 Information Processing Society of Japan

表 A·1　各エージェントの役割と使用モデル

エージェント	役割	モデル
recon	ファイル一覧の作成と製品の同定	Sonnet 5
doc-collector	公式文書の収集と正規機能の一覧化	Sonnet 5
file-assigner	各ファイルの種別に応じた担当の割り当て	Sonnet 5
chunk-splitter	担当ファイルのディレクトリ単位での分割	Sonnet 5
config-auditor	設定ファイルの解析と候補の抽出	Opus 4.8
code-auditor	コードの解析と候補の抽出，文書照合の初期判定	Opus 4.8
decompiler	ELF バイナリの逆コンパイル	Opus 4.8
output-merger	各分割の出力の統合	Sonnet 5
chunk-merger	分割をまたいだ候補の機能単位への再結合	Opus 4.8
viability-assessor	候補の動作可能性と意図性の評価	Opus 4.8
doc-checker	文書照合の初期判定の詳細な検証	Sonnet 5
platform-researcher	判断が困難な候補のプラットフォーム調査	Sonnet 5
chain-builder	複数の候補を組み合わせた攻撃連鎖の構成	Opus 4.8
adversarial-reviewer	三段階の敵対的レビューによる最終確認	Opus 4.8
report-writer	検出レポートの生成	Opus 4.8

育目的であることを確認したうえで，申請に基づいて提供する．DarkWrt は著者らが OpenWrt をもとに構築したものであり，公開を妨げる第三者の権利は存在せず，制約は悪用可能性のみに由来する．提供にあたっては，GPL の条件に従い改変部分のソースを併せて渡すとともに，正規の OpenWrt と混同されないよう，不正機能を含む評価用の派生物であることを名称と説明において明示する．DarkWrt の配付は，Web サイト (`https://github.com/ylab-organization-1/darkwrt`) で行っている．

一方，検出レポートの全文は公開しない．レポートには各不正機能の仕組みが，起動の合図となる値や認証情報を含めて記述されており，実行の手順書として利用しうるためである．検出の成否と適合率・再現率の検証に必要な情報は表 2 に示しており，レポートの全文がなくとも本論文の主張は確認できる．

市販製品のファームウェアおよびそれに対する検出結果も公開しない．前者は再配布が許諾されておらず，また配布元を示すこと自体が機種の同定に直結するためである．後者は，静的解析のみに基づくため各挙動の危険性を確定できておらず，この段階での公開が当該製品の利用者を危険にさらしうるためである．

なお本システムは商用のクラウド LLM を基盤とするため，モデルの更新や提供の終了により，将来にわたる完全な再現は保証できない．この制約を補うため，使用したモデルの識別子と実行時期を付録 A.2 に併記する．

A.2　エージェントの定義と使用モデル

本システムでは，利用者はオーケストレータに対して，

システムへの指示

```
please perform static analysis on the
target firmware
```

という指示を与えるのみであり，以降の解析は，オーケストレータと各エージェントの定義に従って自律的に進められる．なお，DarkWrt のように解析対象の文書が供給される場合には，その文書を文書照合の際に参照するよう，上記の指示に英語で追記する．システムを構成する 15 個のエージェントの役割と，各エージェントが基盤とするモデルを表 A·1 に示す．なお，本評価は 2026 年 7 月に実施し，基盤モデルとして Claude Opus 4.8 および Claude Sonnet 5 を用いた．

© 2026 Information Processing Society of Japan